

LEARNING RESOURCE GUIDE

ISC2 CCSP: Certified Cloud Security Professional (Aug 2026) | Professional Participant Workbook

Learning Objectives

By the end of this lecture and its accompanying guide, you will be able to:

- By the end of this guide, you will be able to map security controls precisely to their correct infrastructure layer in the cloud stack.
- By the end of this guide, you will be able to distinguish between the five risk treatment options and apply quantitative versus qualitative analysis methods accurately in exam scenarios.
- By the end of this guide, you will be able to classify security controls by category (physical, administrative, technical) and function (directive, deterrent, preventive, detective, corrective) for any given example.
- By the end of this guide, you will be able to sequence the five BC/DR test types from least to most disruptive and select the appropriate test given scenario constraints.
- By the end of this guide, you will be able to identify the three common Domain 3 exam traps — multi-tenancy risk, management plane exposure, and physical control relevance — and apply the correct mitigations.
- By the end of this guide, you will be able to apply the memory anchor framework (resilient foundation, protective layer, visibility/enforcement, recoverability) to organize Domain 3 concepts under exam pressure.

Introduction

Domain 3 of the CCSP exam — Cloud Platform and Infrastructure Security — carries seventeen percent of the total exam weight, placing it among the most heavily tested domains alongside Domains 1, 2, and 5. The domain spans the entire vertical of cloud infrastructure: from the physical data center environment at the base layer, through networking, compute, virtualization, and storage, up through the management plane and into Identity and Access Management, audit mechanisms, and Business Continuity and Disaster Recovery. The breadth of this domain is both its challenge and its opportunity — a candidate who can organize concepts into clear mental models will find many questions answerable through pattern recognition rather than memorization alone.

This lecture consolidates the highest-priority testable concepts from Domain 3 into a structured review. The approach is intentionally layer-by-layer and category-by-category, mirroring how the exam presents scenarios: a question will describe a control, a threat, or a design decision, and you must map it to the correct layer, category, and function without hesitation. Several recurring trap patterns also appear in Domain 3 questions, particularly around multi-tenancy isolation, management plane security, and the mistaken assumption that physical controls are irrelevant to cloud. This guide addresses each of those traps directly and provides the correct framing.

Cloud security practitioners encounter the concepts in this domain constantly in professional work — designing secure multi-tenant architectures, selecting appropriate BC/DR test types without disrupting production, and defending the management plane against credential compromise. The exam tests the same judgment a

practitioner would need on the job: not whether you can recite a definition, but whether you can apply the right control to the right layer in the right situation.

Core Concepts Explained

Cloud Infrastructure Layer Model

Definition: The structured hierarchy of cloud infrastructure layers — physical environment, network, compute and virtualization, storage, and the management plane — each with its own distinct set of threats and corresponding security controls.

Business relevance: Organizations that fail to assign ownership and controls at each layer create gaps that attackers exploit by moving laterally between layers. Clearly mapping threats and controls to layers enables precise security architecture decisions and supports audit and compliance reporting by demonstrating defense in depth across the stack.

Cloud Security Practitioner relevance: A Cloud Security Practitioner uses the layer model to evaluate proposed architectures, identify which team owns which control surface, and communicate clearly with vendors and auditors about where a given control operates and what it protects.

Real-world example: During a post-incident review at a major financial services firm after a breach involving a rogue hypervisor module, the security team discovered that controls had been mapped only at the application and network layers. No one owned responsibility for compute-layer integrity monitoring. The attacker had installed a malicious kernel module on the hypervisor host, giving them persistent access to multiple tenant VMs without triggering application-layer alerts. The remediation effort included deploying host-based integrity monitoring at the compute layer, enforcing strict hypervisor patch management cycles, and establishing explicit layer-by-layer ownership in the cloud security runbook. The lesson: every layer requires its own dedicated control set and a named owner accountable for it.

Risks or limitations: Skipping layer-by-layer analysis leads to coverage gaps — typically at the hypervisor or management plane level — that are difficult to detect until a breach occurs. The best practice that prevents this is a formal layered security architecture review conducted before a cloud deployment goes to production, with explicit sign-off on controls at each layer.

Data Center Design: Logical vs. Physical

Definition: Physical design addresses the tangible environment of a data center — location selection relative to natural hazards, redundant power (UPS, generators), HVAC with N+1 or better redundancy, and multi-vendor network pathway connectivity. Logical design addresses tenant partitioning, zero-trust network segmentation, and access control models that enforce trust boundaries between workloads.

Business relevance: A data center that is physically resilient but logically permissive is still vulnerable to lateral movement between tenants or workloads. Conversely, a logically hardened architecture hosted in a facility with single-utility power or inadequate cooling creates availability risk that no software control can mitigate. Both dimensions must meet their respective standards.

Cloud Security Practitioner relevance: When evaluating a cloud provider or co-location facility, a Cloud Security Practitioner reviews physical design criteria — SOC 2 Type II reports, physical security attestations, and site inspection findings — alongside logical architecture documentation including network topology diagrams, segmentation policies, and IAM models.

Real-world example: A healthcare cloud provider selected a data center site that met all logical security requirements — strong tenant isolation, micro-segmentation, and zero-trust IAM — but was located two miles

from a regional airport flight path and in a county with only a single electrical utility feed. During a major ice storm, the utility failed and the facility's backup generator ran out of fuel after 36 hours because the supplier could not deliver due to road closures. The outage lasted 11 hours and triggered breach notification obligations under HIPAA because replicated backups were hosted in the same facility. The remediation included relocating to a facility with dual utility feeds from separate substations, contracting with two fuel suppliers, and distributing backups across geographically separated regions. Physical design criteria — power, cooling, and location — are contractual requirements, not suggestions.

Risks or limitations: Physical design failures typically manifest as availability incidents rather than confidentiality breaches, but prolonged availability outages can trigger regulatory reporting and contractual penalties. The best practice is to require physical design criteria (power, cooling, location) to be formally documented in vendor contracts and verified through third-party audits annually.

Risk Treatment Options and Analysis Methods

Definition: Risk treatment encompasses five options: avoid (eliminate the activity creating the risk), mitigate (reduce the likelihood or impact), transfer (shift the risk to a third party such as an insurer), share (distribute risk across multiple parties such as a joint venture), and accept (acknowledge and tolerate the residual risk). Quantitative analysis uses numerical measures — Single Loss Expectancy (SLE), Annualized Rate of Occurrence (ARO), and Annual Loss Expectancy ($ALE = SLE \times ARO$). Qualitative analysis uses subjective ratings such as high, medium, and low.

Business relevance: Choosing the wrong treatment option wastes resources or leaves the organization exposed. Transferring a risk when mitigation would be cheaper and more effective, or accepting a risk that exceeds the board's risk appetite, are both failures of the risk treatment process. Quantitative analysis enables cost-benefit comparisons for controls investments; qualitative analysis is faster and useful when precise data is unavailable.

Cloud Security Practitioner relevance: A Cloud Security Practitioner is regularly asked to justify security investments by quantifying risk. Calculating ALE for a given threat scenario and comparing it against the annual cost of a proposed control is a standard business case format. Understanding when qualitative analysis is appropriate — early-stage assessments, rapidly evolving threat landscapes — versus when quantitative rigor is expected (regulatory submissions, board-level risk reporting) is part of the practitioner role.

Real-world example: A retail cloud operator was evaluating whether to invest in a web application firewall (WAF) to protect its e-commerce platform. The security team used quantitative analysis: each successful SQL injection attack was estimated to result in \$150,000 in breach costs ($SLE = \$150,000$), and based on threat intelligence, the organization estimated two successful attacks per year without the WAF ($ARO = 2$), yielding an ALE of \$300,000. The WAF cost \$80,000 per year. The risk decision was clear — mitigate using the WAF, reducing the ARO to an estimated 0.1 (one attack per decade), lowering the residual ALE to \$15,000. The \$80,000 annual investment reduced expected losses by \$285,000 per year. This is quantitative risk analysis in practice: it converts a security conversation into a financial one that resonates with executives and satisfies audit requirements.

Risks or limitations: The most common exam trap is confusing transfer and share. Transfer moves risk entirely to a third party (cyber insurance), removing organizational exposure. Sharing distributes risk across parties who all retain a portion (joint venture partners co-liable for a shared platform). The best practice is to document which treatment option is selected for each identified risk in the risk register, with the rationale, and review it at least annually or when the threat landscape changes materially.

Security Control Classification: Category and Function

Definition: Security controls are classified by category — physical (tangible barriers and mechanisms), administrative (policies, procedures, and training), and technical (software and hardware-based controls) — and by function — directive (establish rules), deterrent (discourage attacks), preventive (block threats), detective (identify incidents), and corrective (restore normal operations after an incident).

Business relevance: Regulatory frameworks including ISO 27001, NIST SP 800-53, and CSA CCM organize controls using these categories and functions. An organization that can map every deployed control to a category and function can rapidly demonstrate compliance coverage, identify gaps (for example, having no detective controls in a given domain), and prioritize remediation.

Cloud Security Practitioner relevance: In a Cloud Security Practitioner role, classifying controls is a daily activity — designing an access policy (administrative, directive), deploying a SIEM (technical, detective), installing a badge reader (physical, preventive), or writing an incident response playbook (administrative, corrective). The ability to classify quickly also enables faster audit responses when auditors ask for evidence that a specific control category or function is covered.

Real-world example: During a PCI DSS audit for a cloud-hosted payment processing platform, an auditor asked the security team to demonstrate coverage across all five control functions for network security. The team presented: firewall rules (technical, preventive), network IDS alerts (technical, detective), a network security policy (administrative, directive), warning banners on network access systems (technical, deterrent), and a network incident response runbook (administrative, corrective). Each control was mapped explicitly to category and function. The auditor accepted the evidence without a finding. The team had prepared this mapping during their internal pre-audit assessment, which took two hours — far less than the time saved by avoiding an audit finding.

Risks or limitations: Organizations frequently neglect detective controls, deploying strong preventive measures but lacking the visibility to know when those preventive measures have been bypassed. The best practice is to conduct a control function coverage analysis for each critical asset class, confirming that at least one detective control is present to alert the team when preventive controls fail.

BC/DR: RTO, RPO, and the Five Test Types

Definition: Recovery Time Objective (RTO) is the maximum acceptable elapsed time from a disaster declaration to the restoration of normal operations. Recovery Point Objective (RPO) is the maximum acceptable amount of data loss, measured as the time window since the last good backup or replication synchronization. The five test types, from least to most disruptive, are: tabletop (discussion only), walkthrough (step-by-step plan review), simulation (realistic scenario exercise without system impact), parallel (recovery systems brought online while production remains running), and full interruption (production actually failed over to recovery systems).

Business relevance: RTO and RPO directly determine infrastructure investment levels: a four-hour RTO can be met with standard backup and restore procedures, while a one-minute RTO requires active-active replication across geographically separated regions — at significantly higher cost. Organizations that set RTO and RPO targets without understanding the cost implications either under-invest and fail to meet them, or over-invest and waste budget on capabilities they do not need.

Cloud Security Practitioner relevance: A Cloud Security Practitioner is frequently involved in BC/DR planning and testing. Selecting the appropriate test type for a given business context — a financial services firm may not be permitted to run a full interruption test on its trading platform during market hours — and ensuring that test results drive actual remediation rather than being filed and forgotten are core responsibilities.

Real-world example: A cloud-hosted insurance claims processing platform had an RPO of four hours and an RTO of two hours, supported by hourly snapshot replication to a secondary region. The security team had been conducting annual tabletop tests only. When an actual ransomware incident struck, the recovery team discovered that the runbook had not been updated since the platform migrated to a new database engine eighteen months earlier. The restore procedures referenced tools and commands that no longer applied. Recovery took eleven hours instead of two, missing the RTO by a factor of five. Following the incident, the organization implemented quarterly walkthrough tests and annual parallel tests, with a full interruption test every two years. Critically, they also established a runbook update gate: no infrastructure change could be merged without a corresponding runbook review. The best practice is to test at a level of disruption that reveals gaps, not merely confirms what you already know.

Risks or limitations: The most common BC/DR failure is testing at the tabletop level only, which validates comprehension of the plan but not its executability. The best practice is to escalate through the five test types progressively, using parallel tests as the standard annual practice and reserving full interruption for systems where the risk of an untested recovery is greater than the risk of a planned test outage.

Practical Applications

The following scenarios illustrate how Domain 3 concepts translate into specific professional decisions and actions for a practitioner working in cloud security.

Evaluating a Cloud Provider's Physical and Logical Security Posture

A Cloud Security Practitioner at a mid-sized financial services firm is conducting a due diligence review of a prospective infrastructure-as-a-service provider before migrating the firm's trading analytics workloads. The practitioner requests the provider's most recent SOC 2 Type II report and reviews the physical security section, confirming that the data center sites are located away from flood plains and seismic zones, have dual utility power feeds from separate substations, N+2 HVAC redundancy, and biometric plus badge access controls with visitor escort requirements. Simultaneously, the practitioner reviews the logical architecture documentation, confirming that tenants are isolated using dedicated VLAN segments enforced at the hypervisor layer, that the management plane requires multi-factor authentication and is accessible only from designated jump hosts, and that all management actions are logged to an immutable audit trail. The practitioner then presents findings to the CISO in a structured format mapping each requirement to its layer (physical or logical), its control category (physical, administrative, technical), and its function (preventive, detective, etc.), with evidence references. This structured layer-by-layer review ensures that no security dimension is assumed rather than verified, and produces documentation that satisfies the firm's vendor risk management policy.

Selecting the Right BC/DR Test Type for a Regulated Environment

A Cloud Security Practitioner at a healthcare cloud provider is planning the annual BC/DR test for the organization's electronic health records platform. The platform has an RTO of four hours and an RPO of one hour, and the business cannot tolerate a production outage during the test because patient care workflows depend on the system around the clock. The practitioner evaluates the five test types and rules out full interruption (would cause a production outage) and simulation (would not test the actual recovery systems). A parallel test is selected: the recovery environment in the secondary region is brought online and patient record replication is validated end-to-end while production continues running. The test reveals that replication lag has grown from the expected fifteen minutes to forty-seven minutes over the past quarter because a recent database schema change increased replication payload size. The RPO of one hour is still technically met, but the margin has narrowed significantly. The practitioner raises this as a risk item, initiates an optimization project to

reduce replication lag, and updates the BC/DR plan to include a quarterly replication lag monitoring check as a formal gate. The test outcome directly drives a remediation action — demonstrating the value of testing at a level of disruption that reveals operational drift.

Responding to a Management Plane Compromise Scenario

During a threat intelligence briefing, a Cloud Security Practitioner at an enterprise SaaS company learns that a threat actor group has been targeting cloud management consoles by exploiting reused credentials obtained in third-party data breaches. The practitioner conducts an immediate review of the organization's management plane access controls and finds that three administrator accounts are using passwords that appear in publicly available credential dumps, and that two of those accounts do not have multi-factor authentication enrolled despite a policy requiring it. The practitioner immediately locks the compromised accounts, forces a credential reset for all management plane users, enforces MFA enrollment as a conditional access requirement (users cannot authenticate without it), restricts management plane access to a dedicated administrative subnet accessible only through a hardware security key-authenticated VPN, and enables comprehensive management plane logging to the SIEM with alerting on any access from unrecognized IP ranges. The practitioner also initiates a review of all infrastructure changes made by the three accounts in the preceding sixty days to check for unauthorized modifications. This response demonstrates the best practice principle that the management plane must be treated as the highest-value target in the cloud environment: once compromised, it provides control over the entire infrastructure, so access must be restricted, logged, and continuously monitored.

Best Practices

- **Perform a layer-by-layer security control gap analysis before any cloud deployment.** Map every threat scenario to the layer it targets and confirm that at least one preventive and one detective control exists at that layer. Document the owner responsible for each layer's controls. Use this map as an input to your organization's risk register and review it quarterly or after any significant infrastructure change.
- **Always document risk treatment decisions in a formal risk register with the selected treatment, the rationale, the residual risk level, and a review date.** Risk registers that capture only the initial risk rating without recording the treatment decision and residual risk create audit gaps and make it impossible to demonstrate that risks have been actively managed over time. Include a link to supporting evidence — a control configuration screenshot, a contract clause for transferred risk, an acceptance sign-off from the appropriate risk owner.
- **Use quantitative risk analysis ($SLE \times ARO = ALE$) whenever you need to justify a security investment to business leadership.** Qualitative labels like 'high risk' are difficult to act on. Translating a threat scenario into an expected annual dollar loss, comparing it against the cost of a proposed control, and presenting the net risk reduction as a return on security investment converts the conversation from technical to financial — which is the language leadership uses to make budget decisions.
- **Test your BC/DR plan at the highest practical level of disruption, not the most comfortable level.** Organizations that test only at the tabletop level year after year develop false confidence. A plan that sounds correct in a conference room discussion frequently breaks down when actual systems are restored in a real or simulated recovery scenario. Aim to run a parallel test at minimum annually; schedule a full interruption test for non-critical systems at least every two to three years to validate the complete recovery chain.
- **Treat the management plane as a separate, hardened security zone with its own access controls, logging, and monitoring.** The management plane — cloud console, orchestration APIs, infrastructure automation tooling — controls the entire environment. Compromising it is equivalent to compromising every resource it

manages. Require hardware MFA, restrict access to dedicated administrative networks, log every action to an immutable audit trail, and alert on any access from unrecognized sources within minutes, not hours.

Common Mistakes and Misconceptions

Misconception: Confusing risk transfer and risk sharing on exam questions.

Correct approach: Transfer moves risk entirely to a third party (for example, purchasing cyber liability insurance transfers the financial risk of a breach to the insurer). Sharing distributes risk across multiple parties who each retain a portion (for example, a joint venture where both partners are liable for a shared platform). The correct practice is to identify whether residual liability remains with the organization — if it does, the treatment is sharing, not transfer.

Misconception: Assuming that physical security controls are not in scope for cloud security because the candidate does not manage physical data centers.

Correct approach: Domain 3 explicitly includes physical environment security, and cloud providers are responsible for physical controls even when customers never visit the facility. A Cloud Security Practitioner must verify physical security posture through provider attestations (SOC 2, ISO 27001 physical security controls) and contractual requirements. Physical access logs, visitor management, CCTV, and environmental monitoring are all within scope.

Misconception: Testing only at the tabletop level and treating BC/DR as a compliance checkbox rather than an operational verification activity.

Correct approach: The purpose of BC/DR testing is to discover gaps before an actual incident does. Tabletop tests validate understanding; parallel and full interruption tests validate executability. The correct practice is to progress through test types over time, using each test cycle to identify one or more runbook deficiencies that are formally tracked to remediation.

Misconception: Neglecting detective controls in favor of exclusively preventive ones, leaving no visibility when prevention fails.

Correct approach: Every security architecture should include at least one detective control for each critical asset class. Preventive controls reduce the probability of an incident; detective controls ensure you know when one has occurred despite those preventive measures. The correct practice is to conduct a control function coverage analysis and confirm that detective controls (SIEM alerting, log monitoring, IDS) are present and generating actionable alerts.

checklist: Domain 3 Exam Readiness Checklist

Use this checklist to confirm you can handle the most frequently tested Domain 3 scenarios before the exam. Work through each item; if any item is uncertain, return to the relevant lecture.

- ☐ Can I name all five layers of the cloud infrastructure stack (physical, network, compute/virtualization, storage, management plane) and give one example threat and one example control for each layer?
- ☐ Can I distinguish between physical design criteria (power, cooling, location) and logical design criteria (segmentation, IAM, trust boundaries) and assign exam scenarios to the correct category?

- ☐ Can I name all five risk treatment options (avoid, mitigate, transfer, share, accept) and explain the specific difference between transfer and share?
- ☐ Can I calculate Annual Loss Expectancy using SLE and ARO, and explain when quantitative vs. qualitative analysis is appropriate?
- ☐ Can I classify any given control example by both its category (physical, administrative, technical) and its function (directive, deterrent, preventive, detective, corrective)?
- ☐ Can I define RTO and RPO precisely, explain which costs more to reduce, and give an example of a technology that supports each?
- ☐ Can I name the five BC/DR test types in order from least to most disruptive and identify which test type a scenario description is referencing?
- ☐ Can I explain the multi-tenancy risk trap: what the primary threat is (co-tenant data exposure via isolation failure) and what the primary control is (hypervisor security, storage partitioning, network segmentation)?
- ☐ Can I explain why the management plane is the highest-value attack target and what the required controls are (MFA, restricted access, comprehensive logging)?
- ☐ Can I name the three authentication factor types (knowledge, possession, inherence) and two additional factors (location, behavior) and explain what multi-factor authentication requires?
- ☐ Can I name the three federated identity protocols tested in Domain 3 (SAML, OAuth, OpenID Connect) and describe what federated identity enables (cross-organizational authentication)?
- ☐ Can I name the primary audit detective controls in cloud (management plane logs, data plane logs, SIEM correlation, packet capture) and explain what each one monitors?

How to use this: *This checklist covers the high-probability test topics identified in this lecture. An item you cannot answer confidently represents a return-to-study priority, not a gap to guess through on exam day.*

Knowledge Check

Test your understanding before moving on. Answers are shown below each question.

Q1. A cloud security architect is reviewing a proposed data center design. The design document specifies zero-trust network segmentation, dedicated VLAN isolation per tenant, and role-based access control for all infrastructure APIs. Which category of data center design does this represent?

- A) A. Physical design, because it addresses how tenants are separated in the facility
- B) B. Logical design, because it addresses network segmentation, trust boundaries, and access control models
- C) C. Administrative design, because it requires policies and procedures to implement
- D) D. Environmental design, because it addresses the operating environment of the cloud infrastructure

Answer: B. Logical design, because it addresses network segmentation, trust boundaries, and access control models

Q2. An organization purchases cyber liability insurance to cover the financial costs of a data breach. A separate business unit enters a joint venture where both partners share liability for the security of a shared cloud platform. Which risk treatment options do these two scenarios represent, respectively?

- A) A. Mitigation and transfer

- B) B. Transfer and acceptance
- C) C. Transfer and sharing
- D) D. Sharing and mitigation

Answer: C. Transfer and sharing

Q3. A security team at a cloud-hosted retail platform is conducting a BC/DR test. They bring the recovery environment in their secondary region fully online, validate that data has replicated correctly, and test the recovery runbook end-to-end — all while the primary production environment continues serving customers without interruption. Which BC/DR test type does this describe?

- A) A. Full interruption test
- B) B. Simulation test
- C) C. Parallel test
- D) D. Walkthrough test

Answer: C. Parallel test

Q4. A CCSP candidate is reviewing a scenario where an attacker compromised cloud infrastructure orchestration APIs and used that access to modify firewall rules, create new privileged accounts, and export encrypted storage volumes from multiple tenant environments. Which Domain 3 concept does this attack most directly exploit?

- A) A. Multi-tenancy risk, because the attacker accessed multiple tenant environments
- B) B. Physical environment vulnerability, because physical access was not controlled
- C) C. Management plane exposure, because compromising the orchestration layer provided control over the entire infrastructure
- D) D. Audit mechanism failure, because the attacker was not detected by logs

Answer: C. Management plane exposure, because compromising the orchestration layer provided control over the entire infrastructure

Q5. An organization has an RPO of two hours for its cloud-hosted ERP system. The security team is evaluating whether hourly snapshot replication to a secondary region satisfies this requirement. A DR event occurs, and the most recent valid snapshot is from 105 minutes before the failure. Has the RPO been violated?

- A) A. No, because the RPO is two hours and the data loss of 105 minutes is less than two hours
- B) B. Yes, because any data loss beyond the last snapshot violates the RPO
- C) C. Yes, because 105 minutes exceeds the two-hour RPO
- D) D. No, because RPO measures recovery time, not data loss, and the two-hour target has not been exceeded

Answer: A. No, because the RPO is two hours and the data loss of 105 minutes is less than two hours

Reflection Questions

1. Which of the five cloud infrastructure layers do you feel least confident about when it comes to naming the specific threats and controls that apply? What would it take to close that gap before your exam?
2. Think about a cloud environment you work in or have studied. Can you identify at least one control at each layer of the stack, and can you classify each control by both category and function? Where are the gaps?

3. The management plane is described as a high-value attack target. In your current or previous organization, what controls were in place for management plane access? Were they sufficient based on what you now know?
4. If you were asked to design a BC/DR test program for a cloud-hosted healthcare platform with 24/7 availability requirements, which test types would you select for the first three years? How would you escalate the program over time without causing a patient care outage?
5. The memory anchor for this domain is: resilient foundation, protective layer, visibility and enforcement, recoverability. Can you map at least two specific Domain 3 concepts to each of those four pillars without looking at your notes?

Key Takeaways

- Domain 3 carries seventeen percent of the CCSP exam weight — treat it as a high-priority domain and ensure your knowledge of each sub-area is precise, not approximate.
- The cloud infrastructure layer model (physical, network, compute/virtualization, storage, management plane) is the organizing framework for Domain 3 threat and control mapping — knowing which layer a control belongs to is an exam skill.
- Physical design criteria (power, cooling, location) and logical design criteria (segmentation, IAM, trust boundaries) are tested separately — read each exam scenario carefully to determine which category applies.
- Risk transfer and risk sharing are different: transfer moves risk entirely to a third party with no residual organizational liability; sharing distributes risk across parties who each retain a portion.
- $ALE = SLE \times ARO$ is the core quantitative risk formula — practice applying it to scenarios and comparing ALE against control costs to make a risk treatment recommendation.
- The five BC/DR test types in order from least to most disruptive are: tabletop, walkthrough, simulation, parallel, and full interruption — and the parallel test is defined by production continuing to run while recovery systems are activated.
- The three Domain 3 exam traps are: multi-tenancy isolation (not the same as federation), management plane as highest-value attack target, and physical controls being in scope even for cloud-native environments.
- The memory anchor — resilient foundation (physical design), protective layer (security controls), visibility and enforcement (IAM and audit), recoverability (BC/DR) — provides a four-pillar mental model for organizing Domain 3 under exam pressure.

Recommended Next Actions

Put this lecture to work within the next seven days:

6. Work through the Domain 3 Exam Readiness Checklist in this guide and identify any item you cannot answer confidently, then schedule a focused review session for those specific topics before your exam date.
7. Practice calculating ALE for three different threat scenarios using realistic SLE and ARO values, then formulate a risk treatment recommendation and compare it against the cost of a proposed control — do this until the calculation feels automatic.
8. Review the BC/DR plan or runbook for a system you own or support, identify which test type was used in the most recent test, and evaluate whether escalating to the next test type would reveal operational gaps that the current test level cannot detect.

9. Map the security controls currently deployed in a cloud environment you have access to against the five control functions (directive, deterrent, preventive, detective, corrective) and confirm that at least one detective control is present for each critical asset class.